

O documento aborda a necessidade do desenvolvimento de software seguro devido ao aumento de ataques cibernéticos.

A segurança do Software se baseia em 4 pilares: Confidencialidade, Integridade e Disponibilidade e Não Repúdio.

A Segurança deve ser um processo contínuo, não um destino. As melhores práticas envolvem:

→ Perímetro de Segurança: Proteger as segões-chave do software contra acesso não autorizado.

→ Superfície de Ataque: Reduzir ao mínimo todos os pontos de entrada que um invasor possa explorar.

⇒ Princípios OWASP: Incluem aplicar defesa em profundidade (segurança em camadas), usar um modelo de segurança positivo (Whitelisting) para rejeitar tudo o que não é permitido, falhar com segurança e executar com privilégio mínimo.

O desenvolvimento seguro exige a integração da segurança em todas as fases do Ciclo de Vida do Desenvolvimento de Software (SSDLC): Requisitos, Design e Arquitetura, Implementação e Testes.

Modelos como Microsoft SDL (prescritivo) e BSIMM (descritivo/benchmarking) distribuem práticas de segurança por todo SDLC.